

Password and Multi-Factor Authentication Standard

Version 5.0 | Owner: Security Operations | Effective 2026-01-20 | Next review 2027-01-20

1. Purpose

This standard sets the requirements for Zuqah Technologies account credentials: what a password must be, how multi-factor authentication is registered and used, and what to do when either is lost or compromised.

2. Password requirements

Requirement	Rule
Minimum length	14 characters
Complexity	No character-class requirement
Expiry	None — passwords do not expire on a schedule
Reuse	Last 10 passwords cannot be reused
Blocked list	Common and breached passwords are rejected at the point of setting

Two of these surprise people, so the reasoning is stated plainly.

There is no complexity requirement. Length matters far more than character variety. A passphrase of four unrelated words is stronger than a short string with substitutions, and is easier to remember and to type.

Passwords do not expire. Forced rotation makes people choose weaker passwords and vary them predictably. Passwords are changed when there is a reason to change them, not on a calendar.

3. Multi-factor authentication

MFA is required for every Zuqah Technologies account without exception, including contractors and service accounts where technically possible.

3.1 *Approved methods*

In order of preference:

- 1. Passkey on the device — phishing-resistant, and the default for new accounts
- 2. Authenticator app with number matching
- 3. Hardware security key — for privileged roles, see the Privileged Access standard

SMS and voice calls are not approved and are not offered. They are vulnerable to interception and to number porting.

3.2 Registering

New starters register during first sign-in, as part of the process in the New Starter IT Setup Checklist. At least two methods must be registered, so that losing one device does not lock the account.

4. Replacing a phone

This is the single most common cause of a lockout, and it is avoidable.

Before giving up the old device, register a method on the new one. The old device can then be removed. This takes two minutes and avoids the process below.

If the old device is already gone:

- 1. Sign in on a Zuqah Technologies laptop that has previously been used with the account.

An existing device can often authorise a new one without a reset.

- 2. If that is not possible, contact the Service Desk for an identity-verified

reset. This requires a video call with a Zuqah Technologies photo ID and takes about 20 minutes. It cannot be done over email or chat.

The verification step is not negotiable. It is the control that prevents an attacker with a plausible story from taking over an account by claiming to have lost a phone.

5. Lockouts and resets

An account locks after 10 failed sign-in attempts and unlocks automatically after 15 minutes. Most lockouts resolve themselves; waiting is faster than raising a ticket.

Self-service reset is available at any time from the sign-in page, using a registered MFA method. Service Desk assistance is needed only where no registered method is available, and follows the verification in section 4.

6. If a credential is compromised

Report immediately to Security Operations — within the hour, and before doing anything else. Speed matters far more than certainty; a report that turns out to be nothing costs nothing.

Indicators worth reporting:

- An MFA prompt you did not trigger
- A sign-in notification from an unfamiliar location
- Entering the password into a site that later looked wrong
- Any suspicion at all, however vague

There is no penalty for reporting a mistake, including entering credentials into a phishing site. There is a real cost to reporting it late. Zuqah Technologies's position is that people who report quickly are doing exactly the right thing.

7. Password managers

Zuqah Technologies provides a password manager to all employees; it is in the Software Portal. Using it is strongly encouraged for both Zuqah Technologies and personal credentials.

Passwords must not be stored in browser profiles synchronised to a personal account, in documents, in spreadsheets, or in notes applications.

8. Shared and service accounts

Shared human accounts are not permitted. Where several people need the same access, that is a permissions problem and is solved with a group, not a shared password.

Service accounts are owned by a named team, hold credentials in the approved secret store, are excluded from interactive sign-in, and are reviewed every six months.

this document describes no real organisation's policy.*

Sample content for demonstration purposes. Zuqah Technologies is a fictional company and this document describes no real organisation's policy.